BULACAN STATE UNIVERSITY

SARMIENTO CAMPUS • CITY OF SAN JOSE DEL MONTE, BULACAN

DEPARTMENT OF INFORMATION TECHNOLOGY

IT 403P: INFORMATION ASSURANCE AND SECURITY

Academic Year 2026–2027 | First Semester

CAPSTONE SECURITY POLICY WRITING ACTIVITY

CAPSTONE SECURITY POLICY PACKAGE

Security Policies and Governance

LabSync: An IoT-Based IT Laboratory Availability and Equipment Monitoring System

Governing Framework: NIST Cybersecurity Framework (CSF) 2.0 Alignment

Course & Activity	IT 403P • Capstone Security Policy Writing (Security Policies and Governance)
Author / Student	**Andrei A. Gabito**
Capstone Group & Section	**Group 3 (G03) • BSIT 4E2**
Target System	LabSync Laboratory Availability, Equipment Monitoring, and Key Tracking System
Institutional Scope	BulSU Sarmiento Campus IT Laboratories (Building 2, Rooms 201–206, 303–304)
Document Version	Version 1.3 • Academic Submission
Proposed Effectivity Date	November 1, 2026 (Subject to institutional approval)
Submission Date	October 2026

RISK ASSESSMENT METHOD

Likelihood and impact are evaluated on a standardized three-point qualitative scale to determine realistic security priorities for the LabSync system:

- **Likelihood:** 1 = Unlikely (requires specialized access, complex timing, or rare circumstances), 2 = Possible (can occur during routine laboratory operations or via readily accessible interfaces), 3 = Likely (expected to occur frequently due to missing technical safeguards or standard operational turnover).
- **Impact:** 1 = Minor (localized operational inconvenience, no data loss or privacy exposure), 2 = Significant (partial service disruption, recoverable data loss, or privacy risk affecting individual records), 3 = Severe (system-wide compromise, unrecoverable data loss, physical security bypass, or statutory privacy violation).
- **Priority Score:** Priority is calculated as Score = Likelihood × Impact.
- **Priority Levels:** 1–2 = LOW, 3–4 = MEDIUM, 6 = HIGH, 9 = CRITICAL.

All risk ratings represent qualitative assessments derived from active repository architecture audits, verified hardware circuit boundaries, and campus operational conditions.

Framework Alignment: These policies use the NIST Cybersecurity Framework (CSF) 2.0 to organize LabSync security responsibilities. *Govern* supports policy ownership and approval; *Identify* supports asset and risk assessment; *Protect* covers access, privacy, and credential safeguards; *Detect* and *Respond* support monitoring and incident handling; and *Recover* supports backup and restoration planning. This is an academic alignment, not a claim of certification or formal compliance.

POLICY 1 — ACCOUNT LIFECYCLE, AUTHENTICATION, AND ROLE-BASED PRIVILEGE MANAGEMENT

1.1 Policy Identity and Purpose

- **Owner:** MIS Staff (Operational Lead) / System Administrator
- **Approving Authority:** IT Department Head
- **Version and Proposed Effectivity:** Version 1.3 | November 1, 2026 (Subject to institutional approval)
- **Security Objective:** Establish strict controls over credential protection, administrative privilege segregation, session persistence, and account termination to prevent unauthorized privilege escalation and audit trail degradation. This policy aligns with NIST CSF 2.0 functions *PROTECT (PR.AC-01, PR.AC-04)* and *GOVERN (GV.PO-01)*.

1.2 Scope and Context

This policy governs administrative and faculty web application access, user onboarding, password storage, session lifetimes, role-based authorization, and account deactivation across the LabSync web portal. It applies to the IT Department Head, Program Coordinators, MIS Staff, Faculty Members, and Student On-the-Job Trainees (OJTs). It excludes unauthenticated public student workstation reporting (governed by Policy 2) and microcontroller hardware tokens (governed by Policy 4). It assumes the web application operates behind an edge reverse proxy terminating secure HTTPS traffic.

1.3 Risk Basis

1. Risk A (R3) — Administrative Session Hijacking on Unattended Workstations:

- *Asset:* Authenticated administrative and faculty web sessions.
- *Threat and weakness:* Opportunistic session hijacking on shared laboratory computers caused by persistent "remember me" session settings that exempt users from inactivity timeouts.
- *Consequence:* An unauthorized person using an unattended terminal can perform administrative actions, alter schedules, or view restricted records without entering credentials.
- *Current safeguards:* Standard authenticated sessions enforce a 10-minute inactivity timeout, and user account status is verified upon each privileged request.
- *Likelihood, impact, and priority:* Likelihood = 2, Impact = 3, Priority = HIGH (Score: 6).
- *Brief rating rationale:* Laboratory workstations are shared by hundreds of students daily; persistent session tokens on unattended browsers present an active takeover risk.
- *Related clauses:* Clauses 1.4.3 and 1.4.6.

2. Risk B (R5) — Historical Audit Trail Truncation via Faculty Account Deletion:

- *Asset:* Historical key custody transactions and laboratory maintenance records.
- *Threat and weakness:* Permanent deletion of former faculty accounts from the system, which severs historical foreign-key relationships and leaves audit records without user attribution.
- *Consequence:* Historical key checkouts and equipment repair records lose instructor attribution, degrading institutional auditability and accountability.
- *Current safeguards:* Account deletion is blocked for MIS Staff and OJT accounts; active administrative leadership accounts are protected against removal.
- *Likelihood, impact, and priority:* Likelihood = 2, Impact = 2, Priority = MEDIUM (Score: 4).
- *Brief rating rationale:* Faculty turnover occurs each semester; hard deletion of user accounts destroys essential historical custody records.
- *Related clauses:* Clause 1.4.5.

3. **Risk C (R11) — Administrative Role Boundary Blur and Unauthorized Privilege Elevation:**
   - *Asset:* Administrative configuration settings, account provisioning, and key approval workflows.
   - *Threat and weakness:* Misaligned administrative permissions or inadequate role segregation between academic coordination and department executive leadership.
   - *Consequence:* Non-executive personnel could authorize out-of-schedule key releases or modify core administrative accounts without executive oversight.
   - *Current safeguards:* The application middleware enforces distinct permission tiers separating general administrative tasks from exclusive executive approvals.
   - *Likelihood, impact, and priority:* Likelihood = 1, Impact = 3, Priority = MEDIUM (Score: 3).
   - *Brief rating rationale:* Technical permission tiers exist in code, but explicit policy governance is necessary to prevent operational boundary blur between academic coordinators and department heads.
   - *Related clauses:* Clause 1.4.2.

1.4 Mandatory Policy Clauses

1. **Clause 1.4.1 — Cryptographic Password Protection:** All user passwords must be hashed using salted bcrypt with a minimum work factor of 12 rounds prior to database storage. Plaintext passwords shall never be stored, displayed, transmitted, or written to system logs. (*Implemented*)
2. **Clause 1.4.2 — Administrative Privilege Boundaries:** User permissions must strictly observe assigned administrative tiers. Only the IT Department Head shall approve out-of-schedule key releases or export official room status reports. Program Coordinators may manage schedules and academic accounts but are excluded from key approvals. MIS Staff manage daily key custody, and Student OJTs are limited to viewing schedules and logging maintenance tickets. (*Implemented*)
3. **Clause 1.4.3 — Universal Inactivity Timeout:** All authenticated web sessions must terminate automatically after exactly 10 minutes of inactivity. To eliminate session hijacking risks on shared campus computers, persistent session exemptions ("remember me" tokens) must be disabled in production environments. (*Partially implemented; standard 10-minute timeout is active, but persistent session exemption requires removal*)
4. **Clause 1.4.4 — Mandatory OJT Account Expiration:** Every Student OJT account must be provisioned with a mandatory end date matching their official training period. The system must verify this date on every privileged request and immediately invalidate access upon reaching the expiration date. (*Implemented*)
5. **Clause 1.4.5 — Prohibition of Permanent Account Deletion:** Permanent database deletion of user records is strictly prohibited across all user tiers. Former personnel and graduating student assistants must be offboarded exclusively by updating their account status to deactivated, preserving historical key checkout and maintenance logs. Existing deletion options for faculty accounts must be replaced with status deactivation. (*Partially implemented; deactivation is enforced for administrative and OJT tiers, but faculty deletion requires refactoring*)
6. **Clause 1.4.6 — Live Session Status Verification:** The system must actively verify account status against the live database on every privileged request. If an account is deactivated or suspended, active sessions must be terminated immediately. (*Implemented*)

1.5 Implementation, Verification, Roles and Enforcement

- **Responsible Roles & Implementation:** MIS Staff implement password hashing standards, configure session timeouts, and manage user provisioning. The IT Department Head reviews role assignments and authorizes privilege extensions.
- **Compliance Verification & Evidence:** Compliance is checked by reviewing authentication configurations, verifying password hash formats in database exports, testing session inactivity timeouts on laboratory workstations, and executing automated authorization tests. Evidence includes test logs, access review summaries, and timeout records.
- **Evidence to Retain:** Authentication and authorization test results, session-timeout test results, and account-review records.
- **Monitoring & Violation Review:** MIS Staff shall inspect the active user directory monthly to confirm that expired OJT accounts and offboarded faculty are deactivated. Suspected credential sharing, unauthorized access attempts, or session tampering must be documented and referred to the IT Department Head for administrative review under the BulSU Student Handbook or Faculty Code of Conduct.
- **Exception Handling:** Temporary privilege extensions or role adjustments must be requested in writing and approved exclusively by the IT Department Head.

POLICY 2 — STUDENT IDENTITY CAPTURE, PRIVACY PROTECTION, AND PC MAINTENANCE REPORTING

2.1 Policy Identity and Purpose

- **Owner:** MIS Staff / Student Laboratory Assistant Supervisor
- **Approving Authority:** IT Department Head
- **Version and Proposed Effectivity:** Version 1.3 | November 1, 2026 (Subject to institutional approval)
- **Security Objective:** Protect student personally identifiable information (PII) during identity capture, prevent ticket queue tampering, establish verifiable verification token lifecycles, and clarify the technical limits of barcode/QR ID validation. This policy aligns with Republic Act 10173 (Data Privacy Act of 2012) and NIST CSF 2.0 *PROTECT (PR.DS-01, PR.DS-02)*.

2.2 Scope and Context

This policy governs student attendance scanning, temporary verification token generation, public workstation maintenance defect reporting, and technician ticket resolution across all BulSU IT laboratories. It applies to enrolled students, laboratory technicians, MIS staff, and student assistants. It excludes university-wide registrar databases and physical ID card printing. It assumes that barcode/QR scanners in laboratories operate over secure local workstation connections.

2.3 Risk Basis

1. **Risk A (R4) — Student Personal Data Exposure via Insecure Identity Capture:**
   - *Asset:* Student personally identifiable information (student ID numbers, full names, course details).
   - *Threat and weakness:* Interception, unmasked public display, or unauthorized logging of student personal data during laboratory attendance scanning.
   - *Consequence:* Statutory privacy violation under RA 10173, unauthorized identity harvesting, or profiling of students.
   - *Current safeguards:* Masked student ID displays (`****-5678`) on public kiosk interfaces and temporary in-memory session holding.
   - *Likelihood, impact, and priority:* Likelihood = 2, Impact = 2, Priority = **MEDIUM** (Score: 4).
   - *Brief rating rationale:* Hundreds of students scan their IDs daily in public laboratory environments; displaying unmasked data would create an immediate privacy vulnerability.
   - *Related clauses:* Clauses 2.4.1 and 2.4.5.

2. **Risk B (R9) — Defamatory or Spam PC Maintenance Ticket Flooding:**
   - *Asset:* Laboratory workstation maintenance ticket queue and technician dispatch workflows.
   - *Threat and weakness:* Unrestricted public submission of maintenance reports lacking rate limiting or automated spam prevention.
   - *Consequence:* Queue flooding, false hardware defect claims, or injection of inappropriate remarks targeting laboratory personnel.
   - *Current safeguards:* Input sanitization stripping executable HTML/JavaScript tags and mandatory laboratory room/PC selection.
   - *Likelihood, impact, and priority:* Likelihood = 2, Impact = 2, Priority = **MEDIUM** (Score: 4).
   - *Brief rating rationale:* Public availability enables prank or automated spam submissions, potentially disrupting technician response times.
   - *Related clauses:* Clauses 2.4.4 and 2.4.6.

3. **Risk C (R12) — Student Verification Token Replay and Inability to Prove Physical Card Authenticity:**
   - *Asset:* Temporary student verification tokens and workstation identity binding.
   - *Threat and weakness:* Intercepted verification tokens replayed from unverified computers; standard printed barcodes and QR codes lack cryptographic proof of physical card authenticity.
   - *Consequence:* A user may capture an HMAC token or photocopy an ID barcode to falsely record attendance without the cardholder being present.
   - *Current safeguards:* Cryptographically signed server-issued HMAC tokens with a strict 5-minute lifespan and originating workstation binding checks.
   - *Likelihood, impact, and priority:* Likelihood = 2, Impact = 2, Priority = **MEDIUM** (Score: 4).
   - *Brief rating rationale:* Signing server-issued tokens prevents payload tampering in transit, but it does NOT prove that a scanned physical card is genuine.
   - *Related clauses:* Clauses 2.4.2, 2.4.3, and 2.4.5.

2.4 Mandatory Policy Clauses

1. **Clause 2.4.1 — Student Data Masking and Privacy:** Student identification numbers and names must be masked on all public-facing laboratory screens, displaying only the last four digits. Backend application logs must never record plaintext student personal details. (*Implemented*)
2. **Clause 2.4.2 — Cryptographic Token Lifespan:** Student verification tokens must be cryptographically signed using server-side HMAC signatures with an expiration window of exactly 5 minutes. The production server must reject default or placeholder signing secrets during startup. (*Implemented*)
3. **Clause 2.4.3 — Scope and Limits of Identity Token Validation:** Laboratory personnel and documentation must explicitly acknowledge that while server-issued HMAC tokens protect token integrity in transit, they do not prove that a physical student ID card is authentic. Physical spot-checks by laboratory instructors remain mandatory during formal examinations. (*Proposed policy control*)
4. **Clause 2.4.4 — Workstation Network Binding:** Scanned student verification tokens must be cryptographically bound to the originating laboratory workstation network identifier. Tokens submitted from mismatched terminals must be rejected. (*Implemented*)
5. **Clause 2.4.5 — Public Report Sanitization and Rate Limiting:** All workstation maintenance reports submitted through public interfaces must be sanitized to strip executable code. Public submission endpoints must enforce rate limiting (maximum 5 submissions per terminal per 15 minutes) to prevent ticket flooding. (*Partially implemented; sanitization is active, but network rate limiting requires gateway deployment*)
6. **Clause 2.4.6 — Technician Ticket Accountability:** All maintenance ticket status updates must record the authenticated technician's user identity, resolution summary, and timestamp. Maintenance tickets shall never be deleted. (*Implemented*)

2.5 Implementation, Verification, Roles and Enforcement

- **Responsible Roles & Implementation:** MIS Staff configure input sanitization, token lifespans, and data masking. Laboratory Technicians verify reported defects and record resolution details.
- **Compliance Verification & Evidence:** Compliance is checked by inspecting public kiosk interfaces for proper masking, verifying token expiration through automated testing, and reviewing maintenance ticket audit trails. Evidence includes redacted kiosk screenshots, ticket logs, and token test reports.
- **Evidence to Retain:** Masked report-response samples, token-validation and rate-limit test results, and ticket audit records.

- **Monitoring & Violation Review:** Technicians and MIS Staff must review maintenance tickets daily. Malicious ticket flooding, submission of false reports, or intentional scanning of unauthorized student IDs shall be escalated to the IT Department Head and investigated under the BulSU Student Disciplinary Rules.
- **Exception Handling:** In the event of system or scanner outages, manual paper sign-in sheets countersigned by the laboratory technician may be used temporarily.

POLICY 3 — PHYSICAL LABORATORY KEY ACCOUNTABILITY, CUSTODY TRANSFER, AND ANTI-TAMPER

3.1 Policy Identity and Purpose

- **Owner:** MIS Staff (Key Custodian Lead)
- **Approving Authority:** IT Department Head
- **Version and Proposed Effectivity:** Version 1.3 | November 1, 2026 (Subject to institutional approval)
- **Security Objective:** Establish strict custody, transfer, and automated tracking procedures for physical laboratory keys, enforce audit logging for key extraction, clearly disclose hardware dock limitations, and mandate dual authorization for out-of-schedule access. This policy aligns with NIST CSF 2.0 *PR.AA-01* and *DE.CM-01*.

3.2 Scope and Context

This policy governs physical key checkouts, custody transfers, return verification, and automated dock monitoring across all eight BulSU IT laboratories (Rooms 201–206, 303, and 304). Automated key sensing and real-time extraction detection are currently supported and calibrated for **Rooms 203 and 204 only**. The remaining six rooms (Rooms 201, 202, 205, 206, 303, and 304) remain pending hardware calibration and require manual logbook tracking. The key box has **no electromechanical locks or solenoids** and cannot physically prevent manual key removal. It assumes the key dock is permanently installed within the monitored MIS Office.

3.3 Risk Basis

1. Risk A (R6) — Unauthorized Key Removal on Calibrated Dock Slots:

- *Asset:* Calibrated physical laboratory keys (Rooms 203 and 204).
- *Threat and weakness:* Physical extraction of keys by unauthorized personnel without an approved teaching schedule or administrative approval.
- *Consequence:* Unsupervised laboratory access, potential hardware equipment theft, or unrecorded room occupancy.
- *Current safeguards:* Hall effect sensor edge detection, immediate transmission of unauthorized removal events, local audible buzzer alarms, and security audit logging.
- *Likelihood, impact, and priority:* Likelihood = 2, Impact = 3, Priority = HIGH (Score: 6).
- *Brief rating rationale:* Although physical removal cannot be mechanically blocked, automated detection on calibrated slots immediately flags and alarms unapproved access.
- *Related clauses:* Clauses 3.4.2 and 3.4.5.

2. Risk B (R7) — Key Status De-synchronization on Uncalibrated Dock Slots:

- *Asset:* Laboratory rooms without completed hardware sensor calibration (Rooms 201, 202, 205, 206, 303, 304).
- *Threat and weakness:* Operating uncalibrated sensor slots under the assumption that automated tracking is active, leading to false or missing occupancy signals.
- *Consequence:* Inaccurate dashboard room occupancy displays, missed unauthorized key removals, or tracking blind spots across multiple rooms.
- *Current safeguards:* Uncalibrated slots are designated as pending verification, and physical sign-out logbooks are maintained by MIS Staff.
- *Likelihood, impact, and priority:* Likelihood = 3, Impact = 2, Priority = HIGH (Score: 6).
- *Brief rating rationale:* Relying on uncalibrated hardware without mandatory manual logbooks would introduce substantial tracking blind spots across six laboratory rooms.
- *Related clauses:* Clauses 3.4.1, 3.4.5, and 3.4.6.

3. Risk C (R8) — Physical Key Theft via Forceful Removal on Lockless Dock:

- *Asset:* All centralized laboratory physical keys.
- *Threat and weakness:* The centralized key box is an open monitoring dock with no mechanical locks, latches, or solenoids to physically prevent key extraction.
- *Consequence:* An unauthorized individual could forcefully take keys from the dock before staff can intervene.
- *Current safeguards:* The key dock is located inside the staff-supervised MIS Office, backed by an audible buzzer alarm triggered upon unauthorized removal.
- *Likelihood, impact, and priority:* Likelihood = 1, Impact = 3, Priority = MEDIUM (Score: 3).
- *Brief rating rationale:* Housing the key box inside the restricted MIS Office provides essential physical defense-in-depth, compensating for the lack of mechanical locking solenoids.
- *Related clauses:* Clauses 3.4.4 and 3.4.6.

3.4 Mandatory Policy Clauses

1. **Clause 3.4.1 — Calibrated Automated Monitoring Scope:** Automated sensor detection, real-time status synchronization, and local alarm sounding shall apply exclusively to the currently calibrated and supported slots (Rooms 203 and 204). Automated tracking claims must not be made for uncalibrated rooms. (*Implemented*)
2. **Clause 3.4.2 — Mandatory Manual Custody for Uncalibrated Rooms:** For laboratory Rooms 201, 202, 205, 206, 303, and 304, MIS Staff and faculty members must conduct physical key issuance and return using the official paper-based key logbook until automated sensing is calibrated and verified. (*Proposed policy control*)

3. **Clause 3.4.3 — Schedule-Based Key Authorization:** Instructors presenting a valid RFID badge during their scheduled laboratory class period are automatically authorized to extract the corresponding room key. The system records the transaction with RFID authentication attribution. (*Implemented*)
4. **Clause 3.4.4 — Dual Authorization for Out-of-Schedule Access:** Any key withdrawal requested outside an instructor's published schedule requires secondary approval issued exclusively by the IT Department Head. Program Coordinators and MIS Staff are strictly prohibited from granting secondary approvals. (*Implemented*)
5. **Clause 3.4.5 — Unauthorized Removal and Incident Logging:** For calibrated slots in Rooms 203 and 204, unauthorized key removal must immediately trigger the local audible buzzer alarm and record an unauthorized extraction event in the security and custody logs. MIS Staff must review the incident and arrange appropriate follow-up. (*Implemented*)
6. **Clause 3.4.6 — Physical Key Box Location Security:** Because the key dock contains no mechanical locking mechanism, the unit must remain permanently installed within the monitored MIS Office. Keys must never be left unattended in laboratory door locks. (*Proposed policy control*)

3.5 Implementation, Verification, Roles and Enforcement

- **Responsible Roles & Implementation:** MIS Staff manage the key dock hardware and oversee daily key custody. The IT Department Head holds exclusive authority for secondary key approvals.
- **Compliance Verification & Evidence:** Compliance is checked by conducting physical extraction tests on calibrated slots (Rooms 203 and 204), inspecting electronic security audit logs for unauthorized removal alerts, and auditing manual sign-out logbooks for uncalibrated rooms. Evidence includes security log exports and physical sign-out sheets.
- **Evidence to Retain:** Key-box test results for Rooms 203 and 204, manual custody logs for uncalibrated rooms, and reconciliation records.
- **Monitoring & Violation Review:** MIS Staff shall inspect physical key slots daily at closing (5:00 PM). Unreturned keys or unacknowledged unauthorized extraction events must be escalated immediately to the IT Department Head. Unaccounted key losses shall be investigated under university property accountability guidelines.
- **Exception Handling:** Emergency access during life-safety incidents shall be handled using emergency master keys held by Campus Security, with an incident report submitted within 24 hours.

POLICY 4 — IOT DEVICE SECURITY, NETWORK PROTECTION, AND SECURITY EVENT HANDLING

4.1 Policy Identity and Purpose

- **Owner:** Technical Lead / IoT Embedded Systems Engineer
- **Approving Authority:** IT Department Head
- **Version and Proposed Effectivity:** Version 1.3 | November 1, 2026 (Subject to institutional approval)
- **Security Objective:** Secure microcontroller communications, mandate cryptographic endpoint authentication, govern firmware credential management, ensure reliable telemetry delivery, and address transport security weaknesses. This policy aligns with NIST CSF 2.0 *PROTECT (PR.IR-01, PR.PS-01)*.

4.2 Scope and Context

This policy governs ESP32 microcontroller firmware, sensor communications, Wi-Fi connectivity, TLS encryption, telemetry heartbeats, and offline event spooling. It addresses the technical finding that firmware currently disables TLS certificate validation and addresses hardcoded Wi-Fi credentials in the repository. It applies to firmware developers, network administrators, and MIS technical staff. It assumes local access points support dedicated laboratory SSID isolation.

4.3 Risk Basis

1. **Risk A (R1) — Man-in-the-Middle Spoofing via Disabled TLS Certificate Validation:**
   - *Asset:* In-transit laboratory occupancy telemetry, key status updates, and device authentication tokens.
   - *Threat and weakness:* Microcontroller firmware disables TLS X.509 certificate validation, allowing connections to proceed without verifying server authenticity.
   - *Consequence:* An attacker on the local network can intercept transmissions, capture device tokens, or inject forged room status messages.
   - *Current safeguards:* Device authentication requires a bearer token in request headers, and traffic is transmitted over HTTPS.
   - *Likelihood, impact, and priority:* Likelihood = 2, Impact = 3, Priority = HIGH (Score: 6).
   - *Brief rating rationale:* Disabling certificate validation neutralizes TLS authentication guarantees on shared campus networks.
   - *Related clauses:* Clause 4.4.2.

2. **Risk B (R13) — Repository Credential Exposure via Hardcoded Wi-Fi Passwords:**
   - *Asset:* Campus Wi-Fi network credentials and IoT endpoint secrets.
   - *Threat and weakness:* Wi-Fi credentials committed directly into version-controlled firmware source code in the repository.
   - *Consequence:* Unauthorized campus network access or lateral reconnaissance if the repository is shared or accessed by unauthorized individuals.
   - *Current safeguards:* The repository is maintained as a private project, and backend API tokens are segregated into environment variables.
   - *Likelihood, impact, and priority:* Likelihood = 2, Impact = 2, Priority = MEDIUM (Score: 4).
   - *Brief rating rationale:* Committing plaintext credentials to source control creates persistent exposure across the project development lifecycle.
   - *Related clauses:* Clauses 4.4.3 and 4.4.4.

3. **Risk C (R14) — Key Telemetry Loss via Persistent Offline Alert Queue Saturation:**
   - *Asset:* Offline security event alert queue stored in microcontroller flash memory.
   - *Threat and weakness:* Prolonged campus network outages that exceed the capacity of the microcontroller's persistent flash storage.
   - *Consequence:* Loss of key extraction security alerts, creating tracking gaps upon network restoration.
   - *Current safeguards:* Events are spooled to persistent non-volatile flash storage using a FIFO queue, and the device performs automatic reconnection retries.
   - *Likelihood, impact, and priority:* Likelihood = 2, Impact = 2, Priority = MEDIUM (Score: 4).
   - *Brief rating rationale:* Extended network disruptions risk overflowing microcontroller storage, leading to dropped incident notifications.
   - *Related clauses:* Clauses 4.4.5 and 4.4.6.

4.4 Mandatory Policy Clauses

1. **Clause 4.4.1 — Cryptographic Device Authentication:** All inbound requests from IoT microcontrollers must supply an authorized cryptographic device bearer token. Requests lacking valid credentials must be rejected immediately. (*Implemented*)
2. **Clause 4.4.2 — Remediation of TLS Certificate Validation:** To eliminate vulnerability to network spoofing, production firmware updates must incorporate institutional root CA certificates or public key pinning to restore genuine server certificate validation. Until deployed, this control is designated as partially implemented. (*Partially implemented; encrypted HTTPS is active, but certificate validation is currently bypassed*)
3. **Clause 4.4.3 — Wi-Fi Credential Rotation and Secret Hygiene:** Wi-Fi credentials previously committed to the repository must be rotated immediately on the physical network. Future firmware builds must load network credentials dynamically via non-committed local headers or captive-portal provisioning, and plaintext credentials must never be committed to source control. (*Partially implemented; active finding requiring network credential rotation and secret decoupling*)
4. **Clause 4.4.4 — Persistent Offline Telemetry Spooling:** When network connectivity is interrupted, the microcontroller firmware must spool key security events to local non-volatile flash storage. Upon reconnection, spooled events must be transmitted sequentially with original hardware timestamps. (*Implemented*)
5. **Clause 4.4.5 — Efficient Heartbeat Telemetry Processing:** Routine microcontroller heartbeat signals must update laboratory availability records in place without expanding historical log tables, preventing database storage bloat. (*Implemented*)
6. **Clause 4.4.6 — Dedicated IoT Network Segregation:** All LabSync IoT microcontrollers must operate on a segregated laboratory Wi-Fi network with client isolation enabled, preventing direct communication between student computers and monitoring devices. (*Proposed policy control*)

4.5 Implementation, Verification, Roles and Enforcement

- **Responsible Roles & Implementation:** The IoT Embedded Systems Engineer manages firmware code, certificate configurations, and credential sanitization. The Network Administrator oversees Wi-Fi network isolation and credential rotation.
- **Compliance Verification & Evidence:** Compliance is checked by reviewing firmware configuration code, auditing git commit histories for exposed secrets, testing TLS connections, and conducting offline network disconnection tests to verify event spooling. Evidence includes compilation logs, sanitized git diffs, and offline recovery logs.
- **Evidence to Retain:** TLS validation test results, credential-rotation records, and offline-event recovery test results.
- **Monitoring & Violation Review:** The administrative dashboard must actively display device online/offline status based on expected heartbeat intervals. Devices remaining offline for over 15 minutes must trigger a technical review. Deliberate network interference or hardware tampering shall be investigated under BulSU IT Security Policies.
- **Exception Handling:** Temporary offline operation during scheduled electrical maintenance is permitted, provided manual key custody procedures are observed.

POLICY 5 — BACKUP, RECOVERY, EXTERNAL NOTIFICATIONS, AND LOG MANAGEMENT

5.1 Policy Identity and Purpose

- **Owner:** Database Administrator / MIS System Administrator
- **Approving Authority:** IT Department Head
- **Version and Proposed Effectivity:** Version 1.3 | November 1, 2026 (Subject to institutional approval)
- **Security Objective:** Establish operational baselines governing runtime secret isolation, safe error handling, scheduled database backups, verifiable disaster recovery simulations, and long-term audit trail retention. This policy aligns with NIST CSF 2.0 *RECOVER (RC.RP-01)* and *PROTECT (PR.DS-11)*.

5.2 Scope and Context

This policy governs database schemas, runtime configuration secrets, automated historical log pruning, external email notification relays, production error handling, and disaster recovery procedures. It explicitly acknowledges that the reviewed repository contains zero automated backup scripts, that Railway cloud volume backups and restoration drills remain unverified, and that administrative audit logs lack automated pruning in application code and are not technically immutable. It applies to database administrators, MIS staff, and hosting managers.

5.3 Risk Basis

1. **Risk A (R2) — Catastrophic Data Loss Due to Missing Application Backup Mechanisms:**
   - *Asset:* Relational database records (user profiles, key assignments, schedules, maintenance history, custody logs).
   - *Threat and weakness:* Cloud database corruption, accidental table deletion, or hosting failure. The application repository contains zero automated backup scripts, and cloud volume backups remain unverified.
   - *Consequence:* Permanent loss of institutional laboratory records, key custody histories, and account authentication data.
   - *Current safeguards:* Database connection pooling, non-destructive user deactivation, and structured migration scripts.
   - *Likelihood, impact, and priority:* Likelihood = 3, Impact = 3, Priority = **CRITICAL** (Score: 9).
   - *Brief rating rationale:* Operating an academic production system without automated, tested offsite backups represents a critical operational vulnerability.
   - *Related clauses:* Clauses 5.4.1, 5.4.2, and 5.4.3.

2. **Risk B (R10) — Transactional Email Webhook Delivery Failure via Quota Exhaustion:**
   - *Asset:* Password recovery links and faculty key notification dispatches.
   - *Threat and weakness:* External email relay quota exhaustion or execution timeouts on third-party webhook relays.
   - *Consequence:* Instructors and staff locked out during password reset, and delayed delivery of critical security notifications.
   - *Current safeguards:* Configured HTTP request timeouts (12 seconds) on email dispatches and rate limiting on password reset requests.
   - *Likelihood, impact, and priority:* Likelihood = 1, Impact = 2, Priority = **LOW** (Score: 2).
   - *Brief rating rationale:* Daily academic email volume is moderate, but third-party relay dependencies introduce unmonitored failure modes.
   - *Related clauses:* Clauses 5.4.5 and 5.4.6.

3. **Risk C (R15) — Database Storage Degradation via Unpruned Administrative Audit Logs:**
   - *Asset:* Database storage capacity and query performance.
   - *Threat and weakness:* Accumulation of administrative audit events over multi-year operational lifecycles. While physical occupancy logs are automatically pruned, administrative audit logs lack an automated pruning or archiving mechanism.
   - *Consequence:* Progressive query latency, degraded report generation times, and potential database container storage exhaustion.
   - *Current safeguards:* Telemetry heartbeats update records in place without row growth, and physical room occupancy logs are pruned after one year.
   - *Likelihood, impact, and priority:* Likelihood = 1, Impact = 1, Priority = **LOW** (Score: 1).
   - *Brief rating rationale:* Administrative events generate low daily volume, but lack of lifecycle archiving creates long-term database storage bloat.
   - *Related clauses:* Clause 5.4.4.

5.4 Mandatory Policy Clauses

1. **Clause 5.4.1 — Strict Secret Segregation:** All database passwords, session secrets, and email webhook tokens must be injected strictly through runtime environment variables. The production server must halt startup if missing or default placeholder secrets are detected. All configuration files containing secrets must be excluded from version control. (*Implemented*)
2. **Clause 5.4.2 — Automated Physical Log Pruning:** Physical laboratory occupancy and key event records must be retained for exactly one calendar year (365 days) to satisfy academic audit requirements. Records exceeding 365 days must be pruned daily via automated database routines. (*Implemented*)
3. **Clause 5.4.3 — Mandatory Logical Database Backup Schedule:** To resolve the absence of backup scripts in the repository, the Database Administrator must configure automated daily logical database exports. Backups must be encrypted and stored in institutional cloud storage with a recovery point objective (RPO) ≤ 24 hours and recovery time objective (RTO) ≤ 2 hours. Cloud volume backup settings on the hosting platform must be verified and documented. (*Missing / not implemented; automated offsite backups are proposed*)
4. **Clause 5.4.4 — Semesterly Disaster Recovery Restoration Simulation:** The technical team must conduct a documented disaster recovery simulation once per academic semester. The test must restore the most recent backup archive to an isolated staging database and verify record counts across users, keys, and schedules. (*Proposed policy control*)
5. **Clause 5.4.5 — Administrative Audit Log Archiving:** Because administrative audit logs lack automated pruning in application code, the Database Administrator must execute an annual archival export of audit logs older than two years to secure offsite cold storage before manual truncation. (*Proposed policy control*)
6. **Clause 5.4.6 — Safe Production Error Suppression:** Centralized error handling in production mode must suppress raw database errors, SQL syntax strings, and server stack traces, returning generic error responses to prevent technical reconnaissance. (*Implemented*)

5.5 Implementation, Verification, Roles and Enforcement

- **Responsible Roles & Implementation:** The Database Administrator configures automated backup jobs and monitors storage growth. MIS Staff manage runtime secrets and verify log pruning routines.
- **Compliance Verification & Evidence:** Compliance is checked by reviewing daily backup archive timestamps, inspecting automated log pruning records, and reviewing semesterly disaster recovery drill reports. Evidence includes encrypted database dump files, restoration verification logs, and error suppression tests.
- **Evidence to Retain:** Backup execution records, restoration-test reports, email-delivery checks, and audit-log retention reviews.
- **Monitoring & Violation Review:** Database storage metrics and backup execution logs must be audited weekly. Backup failures or accidental commits of sensitive configuration files must be reported immediately to the IT Department Head. Exposed credentials must be rotated immediately.
- **Exception Handling:** Emergency database schema adjustments during outages must be executed within transactional wrappers and documented in migration records within 24 hours.